MASTER CYBERSECURITY NOTES

From Beginners to Advanced





- DETECT
- PROTECT
- DEFEND
- RESPOND
- RECOVER

CYBERSECURITY

★ 15 TOPICS – COMPLETE NOTES ★

TOPICS COVERED

1. Fundamentals of Cybersecurity
2. Network Security
3. Cryptography
4. Security Operations
5. Risk Management
6. Threats, Attacks & Vulnerabilities
7. Security Policies & Governance
8. Firewalls, IDS & IPS
9. Web Application Security
10. Password Security & Access Control
11. VPN & Security Protocols
12. Cloud & Mobile Security
13. Ethical Hacking & Penetration Testing
14. Incident Response & Digital Forensics
15. Cybersecurity Tools & Best Practices

> "Security is not just a product, it's a process. Stay Alert. Stay Safe. Stay Secure."

WHAT YOU'LL GAIN

- ☑ Strong Concepts & Clear Notes
- ☑ Real-world Examples
- ☑ Interview Preparation
- ☑ Hands-on Security Skills
- ☑ Step-by-step Learning Path
- ☑ From Beginner to Advanced Level

CONFIDENTIALITY – Keep information private

INTEGRITY – Keep information accurate

AVAILABILITY – Keep systems accessible

AUTHENTICATION – Verify the right users

MONITORING – Detect & respond to threats

★ LEARN. PROTECT. DEFEND. SECURE THE FUTURE. ★

1. Cybersecurity Basics + CIA Triad

What is Cybersecurity?

Cybersecurity is the practice of protecting systems, networks, programs, and data from digital attacks, damage, or unauthorized access. It ensures the confidentiality, integrity, and availability of information.

Why is Cybersecurity Important?

- Protects sensitive data from unauthorized access.
- Prevents financial loss and fraud.
- Ensures business continuity and productivity.
- Protects reputation and builds customer trust.
- Helps organizations comply with laws and regulations.

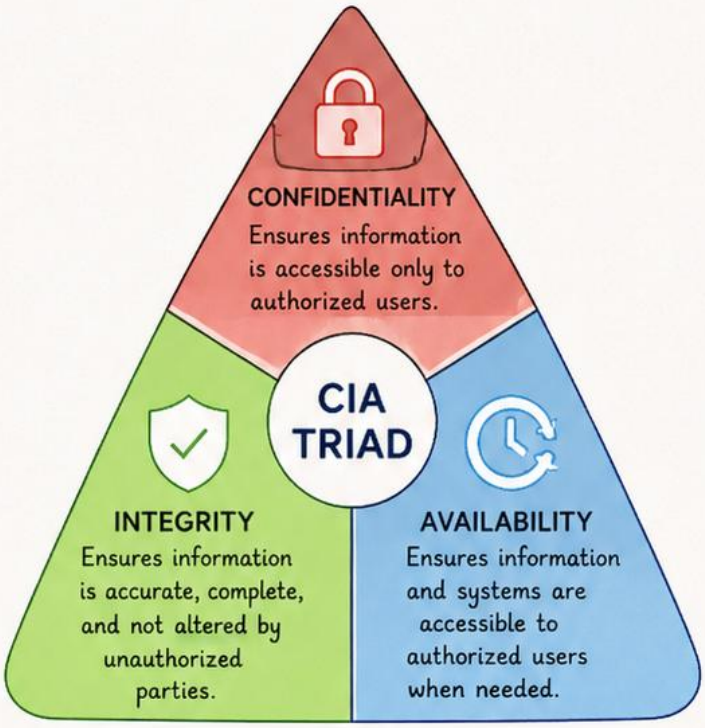
Key Goals of Cybersecurity

- Confidentiality
- Integrity
- Availability
- Authentication
- Authorization
- Non-repudiation

Common Terms

Asset	: Anything valuable that needs protection (data, systems, networks, people).
Threat	: Anything that can cause harm to an asset.
Vulnerability	: Weakness in a system that can be exploited.
Risk	: Combination of threat and vulnerability that may cause loss or damage.
Attack	: An action that attempts to exploit a vulnerability.
Attacker	: An individual or group that performs attacks.
Control	: Safeguards or countermeasures to reduce risk.

The CIA Triad



CIA Triad in Simple Words

Confidentiality → Keep information secret from unauthorized people.

Integrity → Keep information accurate and trustworthy.

Availability → Keep information and systems available when required.

Examples of CIA Triad

Confidentiality	: Using passwords, encryption, access controls.
Integrity	: Using checksums, digital signatures, version controls.
Availability	: Using backups, redundancy, load balancing.

Remember: A strong cybersecurity strategy balances all three principles of the CIA Triad to keep information safe and reliable.

2. Cybersecurity Threats + Attack Types

What is a Threat?

A threat is any potential danger that can exploit a vulnerability and cause harm to systems, data, or networks.

Types of Threats

- Natural Threats : Natural disasters like flood, fire, earthquake.
- Human Threats : Intentional or unintentional actions by people.
- Environmental Threats : Power failure, hardware failure, extreme temperatures.
- Logical Threats : Malware, hacking, software flaws, unauthorized access.

What is an Attack?

An attack is an attempt to exploit a vulnerability to steal, alter, destroy, or disrupt data, applications, or systems.

Common Attack Types

1. Malware : Malicious software designed to damage, disrupt, or gain unauthorized access.
2. Phishing : Tricking users into revealing sensitive information through fake emails/websites.
3. Social Engineering : Manipulating people to divulge confidential information or perform actions.
4. DoS (Denial of Service) : Flooding a system or network with traffic to make it unavailable.
5. DDoS (Distributed DoS) : Similar to DoS but from multiple systems to overwhelm the target.
6. Man-in-the-Middle (MitM) : Intercepting communication between two parties without their knowledge.
7. SQL Injection : Inserting malicious SQL queries to access or manipulate a database.
8. Password Attacks : Trying to guess or crack passwords using brute force or dictionary methods.
9. Zero-Day Exploit : Exploiting a vulnerability before a patch is available.
10. Insider Threat : Threats from trusted individuals within the organization.

Common Threat Actors

- Hackers : Individuals who exploit systems for fun, profit, or revenge.
- Cybercriminals : Organized groups targeting financial gain.
- Nation-States : Governments targeting other countries for espionage or disruption.
- Insiders : Employees or partners who misuse their access.

Threat vs Attack

Threat	Attack
Potential danger	Actual attempt to harm
Exploits vulnerability	Uses a vulnerability
May or may not cause damage	Typically causes damage or disruption
Example: Malware present in system	Example: Malware executed on system

Examples in Real Life

- Phishing email asking for bank details.
- Ransomware locking files and asking for payment.
- DDoS attack making a website unreachable.
- SQL Injection to steal customer data from database.

Impact of Attacks

Data Breach
Loss or exposure of sensitive information.

Financial Loss
Direct financial loss, fraud, or ransom.

Reputation Damage
Loss of trust from customers and partners.

Service Disruption
Downtime of services and productivity loss.



Remember: Identify threats early, understand attack types, and implement security controls to minimize risks.

3. Vulnerabilities + Risk Management

What is a Vulnerability?

A vulnerability is a weakness in a system, application, network, or process that can be exploited by a threat actor to cause harm.

Types of Vulnerabilities

- Technical Vulnerabilities : Software bugs, misconfigurations, unpatched systems.
- Human Vulnerabilities : Lack of awareness, weak passwords, social engineering.
- Physical Vulnerabilities : Unrestricted physical access, theft of devices.
- Process Vulnerabilities : Poor policies, lack of procedures, human errors.
- Network Vulnerabilities : Open ports, weak encryption, insecure protocols.

Common Examples of Vulnerabilities

Unpatched Software	Outdated software can contain known flaws.
Weak Passwords	Easy to guess or default credentials.
Misconfigurations	Incorrect settings in systems, cloud, or devices.
Phishing Susceptibility	Users can be tricked into revealing sensitive data.
Insecure Data Storage	Data stored without proper encryption or access control.

What is Risk?

Risk is the potential that a threat will exploit a vulnerability and cause loss or damage to an organization.

Risk Components

Risk = Threat × Vulnerability × Impact

- Threat → Likelihood of an attack
- Vulnerability → Weakness that can be exploited
- Impact → Potential damage/loss

Risk Level Matrix

Likelihood	Impact		
	Low	Medium	High
High	Medium	High	Critical
Medium	Low	Medium	High
Low	Low	Low	Medium

Risk Assessment Process

1. Identify Assets : Identify important data, systems, and resources.
2. Identify Threats : Determine potential threats to assets.
3. Identify Vulnerabilities : Find weaknesses that can be exploited.
4. Analyze Impact : Determine potential impact on business.
5. Evaluate Risk : Calculate risk level (High / Medium / Low).
6. Treat Risk : Implement controls to reduce or eliminate risk.

Risk Treatment / Mitigation

- Avoid : Avoid activities that cause high risk.
- Reduce : Implement controls to reduce likelihood or impact.
- Transfer : Transfer risk to third party (e.g., insurance).
- Accept : Accept risk when it is within acceptable limits.

Common Risk Management Framework

Identify	Find assets, threats, and vulnerabilities.
Assess	Analyze and evaluate the risk.
Mitigate	Apply controls and safeguards.
Monitor	Continuously monitor and review risks.
Review	Regularly review and improve the process.

Examples of Risk Management Controls

- Administrative Controls : Policies, awareness training, access control, incident response plan.
- Technical Controls : Firewalls, IDS/IPS, encryption, anti-malware, patch management.
- Physical Controls : Locks, CCTV, biometric access, secure data centers.
- Detective Controls : Logs, monitoring, SIEM, vulnerability scanning.

Key Takeaway: Find weaknesses, understand risks, and apply the right controls. This is the foundation of a strong cybersecurity posture.

4. Malware + Social Engineering

• What is Malware?

Malware (Malicious Software) is any software intentionally designed to damage, disrupt, steal data or gain unauthorized access to a system or network.



• What is Social Engineering?

Social Engineering is the art of manipulating people into breaking normal security procedures to gain unauthorized access or sensitive information.



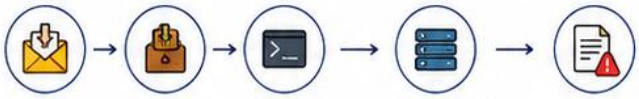
• Types of Malware

Virus	Attaches to legitimate files or programs and spreads when the infected file is executed.
Worm	Self-replicates to spread across networks without needing a host file.
Trojan Horse	Disguised as legitimate software but performs malicious actions once installed.
Ransomware	Locks or encrypts files and demands payment (ransom) to restore access.
Spyware	Secretly monitors user activities and collects sensitive information.
Adware	Displays unwanted advertisements and may track user behavior.
Rootkit	Hides the presence of malware and gives attackers administrator-level access.
Bot / Botnet	Turns infected systems into "bots" controlled remotely, often used for DDoS attacks.

• Common Social Engineering Techniques

Phishing	Fraudulent emails or messages that trick users into revealing credentials or clicking malicious links.
Spear Phishing	Targeted phishing attacks on specific individuals or organizations.
Whaling	Attacks targeting high-profile individuals (CEOs, executives).
Vishing (Voice Phishing)	Using calls to deceive people into sharing sensitive information.
Smishing (SMS Phishing)	Fraudulent SMS messages with malicious links or fake requests.
Pretexting	Creating a fictional scenario (pretext) to obtain information by gaining trust.
Baiting	Offering something attractive (free downloads, USB drives) to lure victims.
Tailgating (Piggybacking)	Following an authorized person to gain physical access to restricted areas.

• Malware Lifecycle



1. Delivery
Malware is delivered via email, websites, USB, etc.

2. Installation
Malware gets installed or executed.

3. Execution
Malware runs its malicious activities.

4. Command & Control (C2)
Malware connects to attacker's server.

5. Actions on Objectives
Steal data, encrypt files, disrupt operations, etc.

• Impact of Malware & Social Engineering



Data Breach
Loss of sensitive or confidential data.

Financial Loss
Direct theft, fraud or business disruption.

Operational Disruption
Downtime, data loss, productivity impact.

Reputation Damage
Loss of customer trust and brand value.

Legal & Compliance Risk
Fines, penalties and legal actions.

• Common Infection Vectors

- Malicious email attachments
- Infected websites / drive-by downloads
- USB / removable devices
- Software cracks and pirated software
- Phishing links
- Network vulnerabilities
- Social engineering attacks

• Best Practices to Prevent Malware

- ✓ Keep OS, software and antivirus up to date.
- ✓ Do not open suspicious emails or attachments.
- ✓ Download software only from trusted sources.
- ✓ Enable firewall and real-time protection.
- ✓ Regularly backup important data.

• How to Protect Against Social Engineering

- ✓ Be cautious with emails, links and unexpected requests.
- ✓ Verify the identity of the requester through another channel.
- ✓ Do not share passwords or confidential information.
- ✓ Enable Multi-Factor Authentication (MFA).
- ✓ Security awareness training for employees.
- ✓ Follow the principle: "Think before you click or share."

Remember: Technology protects systems, but awareness protects people.
Stay alert, stay informed, stay secure.

5. Cryptography + Encryption

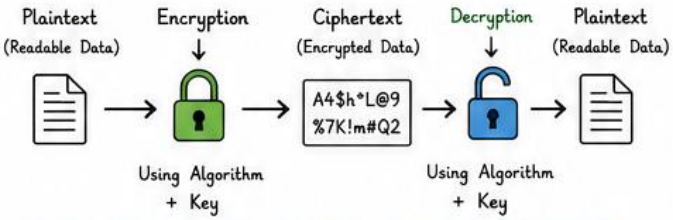
What is Cryptography?

Cryptography is the practice of securing information by converting it into unreadable form so that only authorized parties can access and understand it.

Key Goals

- ✓ Confidentiality – Keep data secret
- ✓ Integrity – Ensure data is not altered
- ✓ Authentication – Verify the identity of parties
- ✓ Non-repudiation – Prevent denial of actions

Encryption vs. Decryption



Encryption converts plaintext into ciphertext.
Decryption converts ciphertext back into plaintext.

Common Encryption Algorithms

Algorithm	Type	Key Size	Use
AES (Advanced Encryption Standard)	Symmetric	128 / 192 / 256 bits	Secure data encryption
DES (Data Encryption Standard)	Symmetric	56 bits	Legacy systems (insecure now)
3DES (Triple DES)	Symmetric	112 / 168 bits	More secure than DES
RSA	Asymmetric	1024 / 2048 / 4096 bits	Secure communication, Digital signatures
ECC (Elliptic Curve Cryptography)	Asymmetric	160 / 256 / 384 bits	High security with smaller keys
SHA-256	Hash	256 bits	Data integrity verification

Hash Function Example (SHA-256)

Input (Data)	Hello, World!
SHA-256 Hash	a591a6d40bf420404a011733cfb7b190 e364706816aba3e25717850c26c9cd0d89d

Features:

- Same input → Same hash
- Different input → Completely different hash
- One-way process (cannot retrieve original data)
- Small change in input → Big change in hash

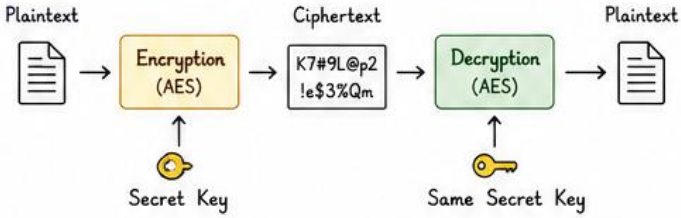
Types of Cryptography

Type	Description	Example
Symmetric Key	Same key is used for both encryption and decryption.	AES, DES, 3DES
Asymmetric (Public Key)	Uses a pair of keys: public key for encryption, private key for decryption.	RSA, ECC, Diffie-Hellman
Hash Functions	Converts data into fixed-size hash value. One-way (cannot be reversed).	SHA-256, SHA-3, MD5

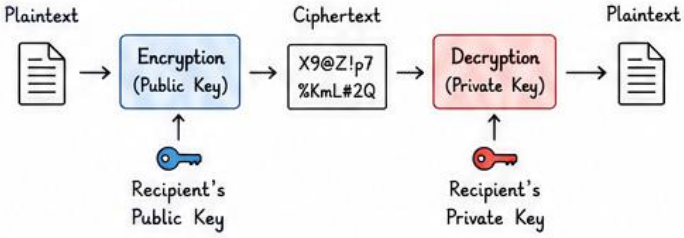
Symmetric vs Asymmetric

Feature	Symmetric Key	Asymmetric Key
Keys Used	One key (secret key)	Two keys (public & private)
Speed	Faster	Slower
Key Distribution	Need secure channel	Public key can be shared
Use Case	Large data encryption	Key exchange, authentication
Examples	AES, DES, 3DES	RSA, ECC

Working of Symmetric Encryption (AES Example)



Working of Asymmetric Encryption (RSA Example)



Applications of Cryptography

- Secure communication (HTTPS, SSL/TLS)
- Online banking & payments
- Data confidentiality (File/DB encryption)
- Email encryption
- Digital signatures (Integrity & authenticity)
- Blockchain & cryptocurrencies

Key Takeaway:
Cryptography protects data.
Encryption keeps it secret, Hashing keeps it trustworthy.

Remember:
Confidentiality + Integrity + Authentication = Secure Information

6. Authentication + Authorization

What is Authentication?



Authentication is the process of verifying the identity of a user, device, or system. It answers the question: "Who are you?"

What is Authorization?



Authorization is the process of determining what an authenticated user is allowed to do. It answers the question: "What can you do?"

Key Difference

Aspect	Authentication	Authorication
Purpose	Verify identity	Determine access rights
Question	Who are you?	What can you do?
Done Before	Access is granted	Access is granted
Example	Login with password	Access to dashboard
Result	Proves identity	Grants or denies access

Authentication Factors

1. Something You Know



- Password
- PIN
- Security Questions

2. Something You Have



- OTP (One-Time Password)
- Smart Card
- Hardware Token

3. Something You Are



- Fingerprint
- Face Recognition
- Iris / Voice

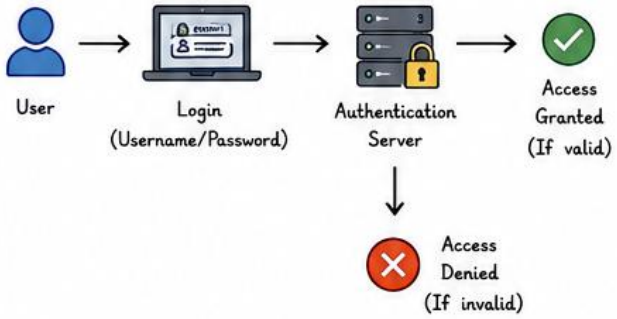
Common Authentication Methods

Password Based	Most common. Use strong passwords and change regularly.
Multi-Factor Authentication (MFA)	Combines two or more factors for stronger security.
Biometric Authentication	Uses unique physical traits like fingerprint or face.
Token Based Authentication	Uses tokens (software/hardware) to generate OTP.
Certificate Based Authentication	Uses digital certificates to verify identity.

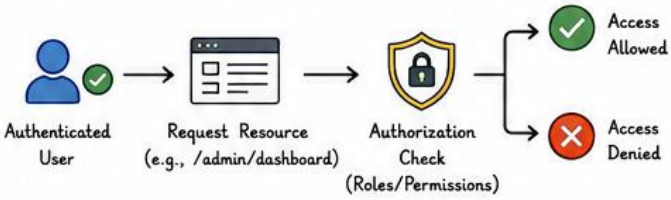
Best Practices

- Use strong passwords (length + complexity).
- Enable MFA wherever possible.
- Never share credentials.
- Use secure protocols (HTTPS, SSH, etc.).
- Regularly review and revoke unnecessary access.

How Authentication Works (Example)



How Authorization Works (Example)



Access Control Models

Model	Description
DAC (Discretionary Access Control)	Resource owner decides who can access. Example: File permissions in OS.
MAC (Mandatory Access Control)	Access based on fixed policies/labels. Example: Military systems.
RBAC (Role Based Access Control)	Access based on user roles. Example: Admin, Editor, Viewer.
ABAC (Attribute Based Access Control)	Access based on attributes like department, location, time, device, etc.

Common Authorization Techniques

- Role Based Access Control (RBAC): Assign roles to users and permissions to roles.
- Permission Based Access: Assign specific permissions to users.
- Least Privilege Principle: Give only the minimum access required to perform a task.
- Need to Know Principle: Access is granted only when necessary.

Real World Examples

Web Applications	Login (Auth) → Access dashboard (Authorization)
Online Banking	Login with OTP (Auth) → Transfer money if permitted (Authorization)
Operating Systems	Login to system (Auth) → Access files based on permissions (Authorization)
Cloud Services (AWS, Azure)	IAM User (Auth) → Access resources based on roles/policies (Authorization)

Key Takeaway:

- Authentication verifies identity – "Who are you?"
- Authorization grants access – "What can you do?"
- Strong authentication + proper authorization = Secure systems.

7. Network Security Fundamentals

• What is Network Security?

Network Security is the practice of protecting computer networks and data from unauthorized access, misuse, disclosure, modification, or disruption.

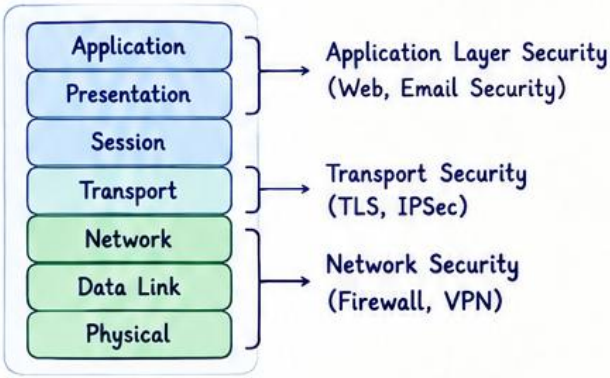
• Goals of Network Security

- Confidentiality – Only authorized users can access data.
- Integrity – Data is not altered without permission.
- Availability – Systems and data are accessible when needed.

• Key Concepts

Term	Meaning
Firewall	Filters traffic based on security rules.
IDS (Intrusion Detection System)	Detects suspicious activity.
IPS (Intrusion Prevention System)	Blocks malicious traffic.
VPN	Creates an encrypted tunnel.
DMZ	Isolated network for public services.
Subnet	Divides a network into smaller parts.

• OSI Model vs Security



• Common Network Attacks

Attack	Description
Sniffing	Capturing network packets.
Spoofing	Faking a trusted device.
DoS / DDoS	Overwhelming a system with traffic.
Man-in-the-Middle	Intercepting communication.
Port Scanning	Finding open ports and weaknesses.

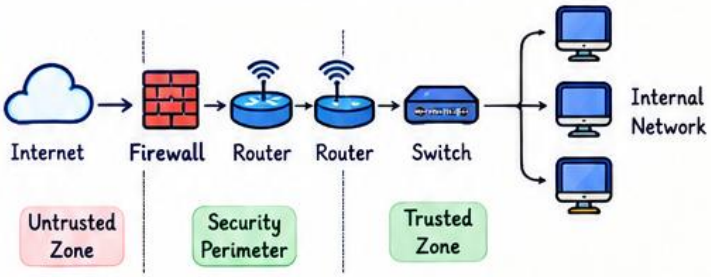
• Types of Network Security

Type	Purpose	Examples
Perimeter Security	Protect network boundary	Firewall, IDS
Internal Security	Protect internal systems	VLAN, NAC
Application Security	Secure apps & data	WAF, HTTPS
Endpoint Security	Protect devices	Antivirus, EDR

• Security Techniques

- **Encryption** – Converts data into unreadable form.
- **Authentication** – Verifies the identity of users/devices.
- **Authorization** – Defines what resources can be accessed.
- **Access Control** – Restricts and monitors access.
- **Intrusion Detection** – Identifies suspicious activity.
- **Firewall** – Blocks harmful traffic.

• Network Security Architecture



• Security Protocols

Protocol	Use
IPSec	Encrypts and authenticates IP traffic.
SSL / TLS	Secures communication (HTTPS).
WPA3	Secure Wi-Fi encryption.
SSH	Secure remote access.

• Best Practices

- ✓ Use strong passwords and multi-factor authentication.
- ✓ Keep systems and software up to date.
- ✓ Encrypt sensitive data.
- ✓ Configure firewalls and IDS/IPS.
- ✓ Avoid unknown links and attachments.
- ✓ Regularly monitor network traffic.

Remember: Network security is not a single tool but a layered defense – **Defense in Depth.**

8. Firewalls + IDS + IPS

What is Firewalls?



A Firewall is a network security device that monitors and filters incoming and outgoing network traffic based on predefined security rules. It acts as a barrier between trusted internal network and untrusted external network.

What is IDS?



An Intrusion Detection System (IDS) monitors network or system activities for malicious activities or policy violations and generates alerts.

What is IPS?



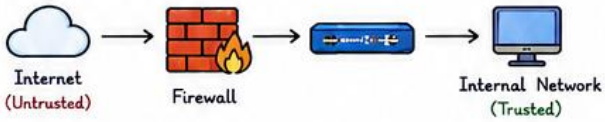
An Intrusion Prevention System (IPS) not only detects but also blocks/prevents malicious activities in real-time.

Firewalls vs IDS vs IPS

Feature	Firewall	IDS	IPS
Full Form	Packet filters traffic based on rules	Detects suspicious activities	Detects and prevents attacks
Purpose	Allow or deny traffic	Monitor and alert	Monitor, alert and block
Action	Allow / Block	Alert only	Alert + Block / Prevent
Placement	At network boundary (perimeter)	Inside network	Inline (in-path of traffic)
When Used	First line of defense	For monitoring & threat detection	For real-time threat prevention
Example	pfSense, Cisco ASA, Check Point	Snort (IDS mode), OSSEC	Snort (IPS mode), Suricata, Cisco IPS

Firewalls

How Firewall Works



Firewall inspects traffic and allows/blocks based on security rules.

Types of Firewalls

Type	Description
Packet Filtering (Stateless)	Filters packets based on IP, port, protocol, etc. Faster but no context of connection.
Stateful Inspection	Tracks connection state (e.g., TCP handshake) and allows valid traffic. More secure.
Application Proxy	Acts as an intermediary for application layer (e.g., HTTP, FTP). Hides internal network.
Next-Generation Firewall (NGFW)	Includes features like IDS/IPS, application control, URL filtering, DPI, etc.

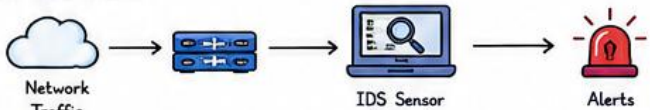
Common Firewall Rules



- Allow established/related connections
- Allow outbound traffic
- Deny all other inbound traffic (by default)
- Allow specific services (e.g., HTTP, HTTPS, DNS)

IDS (Intrusion Detection System)

How IDS Works



IDS passively monitors traffic / host activities and detects attacks.

Types of IDS

Type	Description
NIDS (Network IDS)	Monitors network traffic for suspicious activity. Placed on network segments.
HIDS (Host IDS)	Monitors activities on individual hosts (logs, file changes, system calls).
Signature-based IDS	Uses known attack patterns (signatures) to detect threats.
Anomaly-based IDS	Detects deviations from normal behavior (unknown attacks).

Advantages

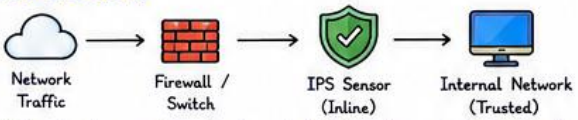
- Detects attacks in early stage
- Helps in log analysis & forensics
- Improves network visibility

Limitations

- Does not block attacks
- High false positives possible
- Needs regular updates

IPS (Intrusion Prevention System)

How IPS Works



IPS sits inline in the network and blocks malicious traffic in real-time.

Types of IPS

Type	Description
NIPS (Network IPS)	Deployed in network to prevent threats in real-time.
HIPS (Host IPS)	Installed on host to prevent malicious activities.
Signature-based IPS	Blocks based on known signatures.
Anomaly-based IPS	Blocks based on abnormal behavior.

Advantages

- Real-time prevention
- Stops known & unknown attacks
- Reduces damage
- High visibility with alerting

Limitations

- Can impact performance
- May block legitimate traffic (need tuning)
- Cost is higher

Key Differences at a Glance

Aspect	Firewall	IDS	IPS
Main Role	Traffic Control	Threat Detection	Threat Prevention
Mode	Active (controls traffic)	Passive (monitors traffic)	Active (monitors + blocks)
Action	Allow / Block	Alert	Alert + Block
Placement	Perimeter	Inside Network	Inline (in path)
Goal	Prevent unauthorized access	Detect attacks	Prevent attacks in real-time
Impact on Traffic	May block traffic	No impact	May block traffic
Examples	pfSense, FortiGate, Cisco ASA	Snort (IDS), OSSEC, Suricata	Snort (IPS), Suricata, Cisco IPS

Best Practices





Keep firewall rules simple & specific



Allow by exception, Deny by default



Regularly update signatures & rules



Monitor logs & alerts continuously



Perform regular security audits



Keep backups of configurations



Remember: Firewall protects the gate, IDS watches for danger, IPS stops the attack.

9. Web Application Security

What is Web Application Security?



Web Application Security is the practice of protecting websites and web applications from threats that exploit vulnerabilities in the application, its logic, and data.

Goals

- ✓ Confidentiality – Protect sensitive data
- ✓ Integrity – Prevent unauthorized changes
- ✓ Availability – Ensure application is accessible
- ✓ Authentication – Verify user identities
- ✓ Authorization – Allow proper access to resources

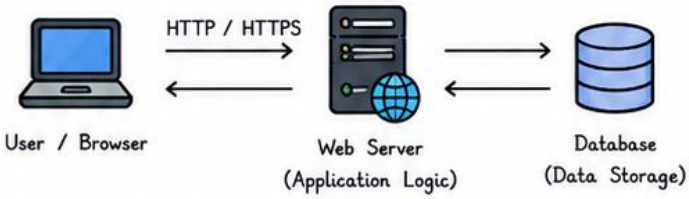
Common Web Application Vulnerabilities

Vulnerability	Description
Injection (SQL/NoSQL/OS)	Attacker injects malicious code/commands to manipulate queries or system.
Cross-Site Scripting (XSS)	Attacker injects malicious scripts that run in other users' browsers.
Cross-Site Request Forgery (CSRF)	Forces a logged-in user to perform unwanted actions on a web application.
Broken Authentication	Weak login/session management allows attackers to gain access.
Sensitive Data Exposure	Application exposes sensitive data (e.g., passwords, keys, PII).
Security Misconfiguration	Incorrect default settings or unnecessary features enabled.
Broken Access Control	Users can access resources/functions they are not authorized to.
Insecure Deserialization	Unsafe object deserialization can lead to remote code execution.
Using Components with Known Vulnerabilities	Outdated libraries/frameworks with known security flaws.
Insufficient Logging & Monitoring	Lack of logging and monitoring makes attacks hard to detect.

Common Web Attacks Explained

Attack	How it Works (Example)
SQL Injection	Attacker inputs: ' OR 1=1 -- to bypass login.
XSS (Stored)	Attacker stores script in database. It runs when other users view the page.
CSRF	Attacker tricks user to click a hidden link while logged in. Action performed without consent.
Command Injection	Attacker executes OS commands through vulnerable input fields.
File Inclusion	Attacker includes and executes malicious files on the server.

How Web Applications Work (Simplified)



Attackers find vulnerabilities in the application layer to access, modify or steal data.

OWASP Top 10 (2021)

A01	Broken Access Control
A02	Cryptographic Failures
A03	Injection
A04	Insecure Design
A05	Security Misconfiguration
A06	Vulnerable and Outdated Components
A07	Identification and Authentication Failures
A08	Software and Data Integrity Failures
A09	Security Logging and Monitoring Failures
A10	Server-Side Request Forgery (SSRF)

Why OWASP Top 10?

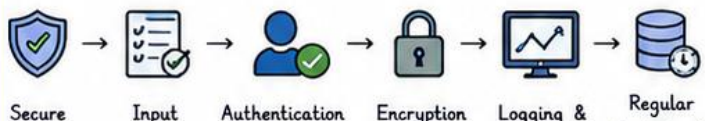
It represents the most critical security risks to web applications based on real-world data and expert consensus.

Security Best Practices



- ✓ Validate and sanitize all user inputs.
- ✓ Use prepared statements / parameterized queries.
- ✓ Encode output to prevent XSS.
- ✓ Use strong authentication and session management.
- ✓ Implement proper access control (least privilege).
- ✓ Use HTTPS everywhere.
- ✓ Keep software, libraries, and frameworks up to date.
- ✓ Store sensitive data securely (hashing, encryption).
- ✓ Implement logging, monitoring, and alerts.
- ✓ Perform regular security testing (SAST, DAST, Pen Testing).

Defense in Depth (Web Application)





Key Takeaway:

Web application security is not just about tools, but about secure coding, proper configuration, regular testing, and continuous monitoring.

Remember:

Secure the logic, protect the data, and trust no input.

10. Password Security + Access Control

What is Password Security?



Password Security is the practice of creating, storing, and managing passwords safely to protect user accounts and systems from unauthorized access.

What is Access Control?



Access Control is the process of regulating who can access what resources in a system. It ensures that users can perform only authorized actions.

Password Security Best Practices



- ✓ Use strong passwords (long + complex).
- ✓ Use a unique password for each account.
- ✓ Enable Multi-Factor Authentication (MFA).
- ✓ Change passwords regularly.
- ✓ Do not share passwords with anyone.
- ✓ Use a password manager to store passwords securely.
- ✓ Beware of phishing and social engineering attacks.

Characteristics of a Strong Password

Characteristic	Guideline
Length	At least 12–16 characters
Complexity	Use uppercase, lowercase, numbers, and special characters
Uniqueness	Do not reuse old passwords
Randomness	Avoid dictionary words, sequences, or personal information
Change Frequency	Change every 60–90 days (recommended)

Common Password Mistakes to Avoid



- ✗ Using simple passwords like password123 or admin.
- ✗ Using personal info (name, DOB, phone number).
- ✗ Reusing the same password across websites.
- ✗ Writing down passwords in insecure places.
- ✗ Sharing passwords via email or chat.

Password Storage Best Practices

- # Store passwords as hashes, not in plain text.
- Use strong hashing algorithms (bcrypt, Argon2, PBKDF2).
- Use salt to protect against rainbow table attacks.
- Never store master keys or recovery keys in plain text.
- Regularly audit and monitor password storage systems.

How Access Control Works



Types of Access Control Models

Model	Description
DAC (Discretionary Access Control)	Resource owner decides who can access. Example: File permissions in OS.
MAC (Mandatory Access Control)	Access based on fixed policies/labels. Example: Military, government systems.
RBAC (Role Based Access Control)	Access based on user roles. Example: Admin, Editor, Viewer.
ABAC (Attribute Based Access Control)	Access based on attributes like department, location, time, device, etc.

Access Control Best Practices



- ✓ Grant least privilege (give minimum access required).
- ✓ Review and revoke unnecessary access regularly.
- ✓ Use role-based access for scalability.
- ✓ Enable MFA for all critical systems.
- ✓ Log and monitor access activities.
- ✓ Enforce strong authentication before authorization.

Authentication vs Authorization

Aspect	Authentication	Authorization
Purpose	Verify who the user is.	Determine what the user can do.
Question	Who are you?	What can you do?
Done Before	Before granting access	After authentication
Example	Login with password / MFA	Access to dashboard / files
Result	Proves identity	Grants or denies access

Common Access Control Techniques

Authentication	Verify identity (Password, MFA, Biometrics).
Authorization	Check permissions (Roles, Policies).
Accounting	Log and audit what users do.
Account Management	Create, update, disable user accounts.



Key Takeaway:

Strong passwords protect your identity.
Proper access control protects your resources.
Both together build a secure system.



Remember:

- Strong Password + MFA = Strong Authentication
- Least Privilege + RBAC = Strong Access Control
- Regular Review + Monitoring = Long-term Security

11. VPN + Security Protocols

What is VPN?

A VPN (Virtual Private Network) creates a secure, encrypted tunnel over the internet, allowing users to access private networks safely and privately.

Why Use VPN?

- ✓ Secure remote access to internal networks
- ✓ Encrypts data over public networks
- ✓ Protects privacy (hides IP address)
- ✓ Access geo-restricted content
- ✓ Safe browsing on public Wi-Fi



How VPN Works (Simplified)



Your data is encrypted on your device → travels through the VPN tunnel → decrypted at VPN server → then goes to the destination.

Types of VPN

Type	Description
Remote Access VPN	Individual users connect to a private network from remote locations.
Site-to-Site VPN	Connects entire networks (e.g., branch office to head office).
Client-to-Site VPN	Used by individual clients to access the organization network.
Extranet VPN	Provides secure access to business partners or vendors.

VPN Protocols

Protocol	Layer	Description	Features
PPTP	Layer 2	Point-to-Point Tunneling Protocol	Fast but less secure (uses MPPE encryption)
L2TP	Layer 2	Layer 2 Tunneling Protocol	Secure tunneling, uses IPSec for encryption
IPSec	Layer 3	Internet Protocol Security	Very secure, used widely in VPNs
SSL/TLS VPN	Layer 5-7	Uses SSL/TLS to create encrypted tunnel	Used in web-based applications
WireGuard	Layer 3	Modern VPN protocol	Lightweight, fast, secure (new generation)

VPN Benefits vs Limitations

Benefits	Limitations
✓ Data confidentiality	✗ May reduce internet speed
✓ Secure remote access	✗ Some VPNs keep logs
✓ Protects on public Wi-Fi	✗ Not 100% anonymous
✓ Bypasses geo-restrictions	✗ Blocked in some countries
✓ Cost-effective for businesses	✗ Misconfiguration risks

Key Takeaway

VPN protects your data in transit by creating an encrypted tunnel. Choose the right protocol based on your security and performance needs.

What are Security Protocols?

Security protocols are a set of rules and standards that define how data is transmitted securely over a network.

Goals of Security Protocols

- ✓ Ensure confidentiality
- ✓ Ensure integrity
- ✓ Ensure authentication
- ✓ Ensure non-repudiation



Common Security Protocols

Protocol	Purpose	Works At	Key Features
SSL/TLS	Secure communication (Website, Web Apps)	Application Layer	Encrypts data between client & server. Used in HTTPS.
IPSec	Secure IP communication (VPNs)	Network Layer	Provides encryption, authentication & integrity for IP packets.
SSH	Secure remote access and file transfer	Application Layer	Used for secure login, command execution, file transfer.
S/MIME	Secure email (Encryption & Signing)	Application Layer	Encrypts and digitally signs email messages.
HTTPS	Secure HTTP (Website Security)	Application Layer	HTTP over TLS. Ensures secure and authenticated web communication.
FTP over TLS (FTPS)	Secure file transfer	Application Layer	FTP with TLS encryption for secure file transfer.
DNSSEC	Secure DNS	Application Layer	Protects DNS data from tampering and cache poisoning.

Comparison of Popular Protocols

Protocol	Main Use	Encryption	Authentication	Port
SSL/TLS	Web Security	Yes	Server (and Client)	443
IPSec	VPNs	Yes	Peers / Certificates	500, 4500
SSH	Remote Access	Yes	Keys / Password	22
S/MIME	Email Security	Yes	Digital Certificates	25, 587
DNSSEC	DNS Security	Yes	Digital Signatures	53

Best Practices

- Always use strong, updated protocols (TLS 1.2/1.3, IPSec, SSH).
- Disable weak or deprecated protocols (PPTP, SSLv3, TLS 1.0/1.1).
- Use certificates from trusted Certificate Authorities.
- Regularly update keys, certificates, and configurations.
- Enforce encryption for data in transit.
- Monitor and log protocol usage and anomalies.



Remember: Encrypt the channel, Authenticate the user, Authorize the access, and Always keep protocols up to date.

12. Cloud + Mobile Security

A. CLOUD SECURITY

What is Cloud Security?



Cloud Security is the practice of protecting data, applications and infrastructure in the cloud from threats and unauthorized access.

Why Cloud Security is Important?

- ✓ Data is stored outside your physical control
- ✓ Shared responsibility model
- ✓ Access from anywhere increases risk
- ✓ High value target for attackers

Shared Responsibility Model

Responsibility	Cloud Provider	Customer
Physical Infrastructure	✓	–
Compute, Storage, Network	✓	–
OS, Middleware, Runtime	✓	✓
Applications, Data	–	✓
Access Management	–	✓

You are responsible FOR security IN the cloud, not OF the cloud.

Common Cloud Security Risks

- ⚠ Data Breaches
- ⚠ Insecure APIs
- ⚠ Account Hijacking
- ⚠ Misconfigured Services
- ⚠ Insider Threats
- ⚠ DoS / DDoS Attacks

Cloud Security Best Practices

- ✓ Use strong IAM (Least Privilege)
- ✓ Enable Multi-Factor Authentication
- ✓ Encrypt data at rest and in transit
- ✓ Regularly scan and patch systems
- ✓ Configure security groups / firewalls
- ✓ Enable logging, monitoring & alerts
- ✓ Backup data regularly
- ✓ Follow secure configuration baselines

Cloud Security Controls

Control	Description
IAM	Manage users, roles and permissions.
Network Security	Use VPC, Security Groups, Firewalls, WAF.
Data Security	Encryption, Key Management, Tokenization.
Monitoring	Centralized logs, threat detection, alerting.
Compliance	Follow standards (ISO 27001, SOC 2, GDPR, etc.).

Popular Cloud Security Services (Examples)



AWS Security Hub



Microsoft Defender for Cloud



Google Cloud Security Command Center



Kubernetes Security



Cloud Security Key Takeaway

Secure configurations, strong access controls, encryption and continuous monitoring are the foundation of cloud security.

B. MOBILE SECURITY

What is Mobile Security?



Mobile Security involves protecting mobile devices, applications and data from threats and unauthorized access.

Common Mobile Security Threats

- ⚠ Malware / Spyware
- ⚠ Insecure Wi-Fi Networks
- ⚠ Phishing / Smishing
- ⚠ Data Leakage
- ⚠ Lost or Stolen Devices
- ⚠ Insecure Apps & Permissions

Mobile Security Best Practices

- ✓ Use strong screen lock (PIN / Password / Biometric)
- ✓ Keep OS and apps updated
- ✓ Download apps only from official stores
- ✓ Review app permissions regularly
- ✓ Enable remote wipe / device tracking
- ✓ Avoid connecting to unknown Wi-Fi
- ✓ Enable encryption on the device
- ✓ Use Mobile Device Management (MDM) for organizations

Mobile App Security Best Practices (For Developers)

- ✓ Validate all user inputs
- ✓ Use secure authentication & session management
- ✓ Encrypt sensitive data (local storage, API calls)
- ✓ Store secrets securely (Keychain / Keystore)
- ✓ Implement certificate pinning
- ✓ Obfuscate code and prevent reverse engineering
- ✓ Test app regularly for vulnerabilities

Common Mobile Security Controls

Control	Description
Device Security	Screen lock, encryption, OS hardening.
Network Security	Secure Wi-Fi, VPN, avoid open networks.
Application Security	Secure coding, input validation, API security.
Data Security	Encrypt data, secure storage, no sensitive data in logs.
Access Control	Strong authentication, least privilege access.
Monitoring	Track device status, jailbroken/root detection, logs & alerts.

Cloud vs Mobile Security (At a Glance)

Aspect	Cloud Security	Mobile Security
Focus	Infrastructure, data, services in cloud	Devices, apps, data on mobiles
Main Risks	Misconfigurations, breaches, insecure APIs	Malware, data leakage, lost devices
Key Controls	IAM, Encryption, Monitoring, Network Security	Device Lock, App Security, Encryption
User Role	Secure configuration & access management	Safe usage & secure app permissions



Mobile Security Key Takeaway

Secure the device, secure the apps, and educate the user.



Remember: Security is a Shared Responsibility. Be Aware, Be Secure!



13. Ethical Hacking + Penetration Testing

What is Ethical Hacking?



Ethical Hacking is the authorized practice of finding vulnerabilities in systems, networks, and applications to help organizations fix them before attackers exploit them.

What is Penetration Testing?



Penetration Testing (Pen Testing) is a simulated cyber attack on a system to evaluate its security by exploiting vulnerabilities.

Goals

- ✓ Identify security weaknesses
- ✓ Assess the impact of vulnerabilities
- ✓ Prevent data breaches
- ✓ Improve overall security posture
- ✓ Ensure confidentiality, integrity, availability

Ethical Hacking Process (Phases)



1. Reconnaissance (Information Gathering)
2. Scanning (Identify Live Targets)
3. Gaining Access (Exploitation)
4. Maintaining Access
5. Analysis & Reporting

Ethical hackers think like attackers, but work with permission to make systems stronger.

Penetration Testing Types

Type	Description
Black Box Testing	Tester has no prior knowledge of the system.
White Box Testing	Tester has full knowledge of the system.
Gray Box Testing	Tester has partial knowledge of the system.
External Testing	Testing from outside the organization.
Internal Testing	Testing from inside the organization.

Common Hacking Techniques

Technique	Description
Reconnaissance	Gather information using OSINT, domain info, emails, social media, etc.
Scanning	Find live hosts, open ports, services using tools.
Enumeration	Extract detailed info (users, shares, versions).
Exploitation	Exploit vulnerabilities to gain access.
Privilege Escalation	Gain higher access/permissions.
Maintaining Access	Create backdoors, establish persistence.
Covering Tracks	Clear logs, hide activities.

✓ Ethical Hacking Best Practices

- ✓ Always get written permission.
- ✓ Follow the rules of engagement.
- ✓ Do no damage.
- ✓ Maintain confidentiality.
- ✓ Report findings clearly.
- ✓ Help fix the issues.

⚠ Important Note

Ethical hacking is legal ONLY with permission. Hacking without authorization is ILLEGAL and punishable under cyber laws.

Penetration Testing Methodology

Phase	Description	Example Tools
1. Planning & Reconnaissance	Define scope, gather information about target.	WHOIS, Maltego, theHarvester
2. Scanning	Discover live hosts, open ports and services.	Nmap, Masscan
3. Enumeration	Enumerate services, users, shares, versions.	Netcat, SMBEnum, Enum4Linux
4. Vulnerability Analysis	Identify and analyze vulnerabilities.	Nessus, OpenVAS
5. Exploitation	Exploit vulnerabilities to gain access.	Metasploit, SQLMap
6. Post-Exploitation	Maintain access, escalate privileges, pivot.	Meterpreter, BloodHound
7. Reporting	Document findings, risk level and remediation.	Dradis, MagicTree

Common Vulnerabilities (OWASP Top 10)



- A01 – Broken Access Control
- A02 – Cryptographic Failures
- A03 – Injection
- A04 – Insecure Design
- A05 – Security Misconfiguration
- A06 – Vulnerable and Outdated Components
- A07 – Identification and Authentication Failures
- A08 – Software and Data Integrity Failures
- A09 – Security Logging and Monitoring Failures
- A10 – Server-Side Request Forgery (SSRF)

Common Tools Used

Information Gathering	WHOIS, theHarvester, Maltego, Recon-ng
Scanning	Nmap, Masscan, Netcat
Vulnerability Scanning	Nessus, OpenVAS, Nikto
Exploitation	Metasploit, SQLMap, Burp Suite
Password Attacks	Hydra, John the Ripper, Hashcat
Web Application Testing	Burp Suite, OWASP ZAP, Dirb, Nikto
Wireless Testing	Aircrack-ng, Kismet, Reaver
Post Exploitation	Meterpreter, Mimikatz, BloodHound

Penetration Testing Deliverables

- ✓ Executive Summary
- ✓ Scope and Methodology
- ✓ Vulnerabilities Found (with risk rating)
- ✓ Proof of Concept (PoC)
- ✓ Impact Assessment
- ✓ Recommendations & Remediation
- ✓ Conclusion



Ethical Hacker Mindset

- Curious but responsible
- Think like an attacker
- Document everything
- Always keep learning
- Help make the world a safer place

Legal Reminder

Always follow local laws and get proper authorization before conducting any security test.

Remember: Ethical Hacking is not about breaking systems, it's about protecting them.

Hack with Ethics, Secure the Future!

14. Incident Response + Digital Forensics

A. INCIDENT RESPONSE

What is Incident Response?

Incident Response (IR) is the structured approach an organization takes to detect, contain, eradicate, and recover from a security incident and minimize its impact.

Goals of Incident Response

- ✓ Minimize impact and damage
- ✓ Restore normal operations quickly
- ✓ Protect data, assets and people
- ✓ Prevent future incidents
- ✓ Comply with legal and regulatory requirements

Incident Response Lifecycle (NIST 6 Phases)



1. **Preparation** — Plan and prepare before incidents occur.
2. **Identification** — Detect and analyze the incident.
3. **Containment** — Limit the impact and prevent spread.
4. **Eradication** — Remove the threat from the system.
5. **Recovery** — Restore systems and return to normal.
6. **Lessons Learned** — Review and improve the process.

• Key Activities in Each Phase

Phase	Key Activities
1. Preparation	Create IR policy, roles & responsibilities, tools, communication plan, training, tabletop exercises.
2. Identification	Monitor alerts, detect incidents, validate, classify, prioritize.
3. Containment	Short-term (isolate systems), Long-term (block IPs, disable accounts, network segmentation).
4. Eradication	Remove malware, patch vulnerabilities, remove backdoors, change passwords.
5. Recovery	Restore from backups, validate systems, monitor closely.
6. Lessons Learned	Post-incident review, document, update controls, improve.

⚠ Common Incident Types

Incident Type	Examples
Malware / Ransomware	Viruses, Trojans, Ransomware attacks
Unauthorized Access	Brute force, Credential stuffing, Insider threat
Data Breach	Sensitive data exfiltration or leakage
Denial of Service (DoS/DDoS)	Service unavailability attacks
Phishing / Social Engineering	Phishing emails, BEC (Business Email Compromise)
Web Application Attacks	SQL Injection, XSS, File inclusion

Best Practices for Incident Response

- ✓ Have a documented IR plan.
- ✓ Keep tools and systems up-to-date.
- ✓ Continuous monitoring and log analysis.
- ✓ Regular backups and tested recovery.
- ✓ Conduct regular drills and awareness training.
- ✓ Communicate effectively during incidents.
- ✓ Follow legal and regulatory guidelines.

Quick Reminder

The faster you detect, the smaller the impact. People, Process, and Technology together make a strong response.

B. DIGITAL FORENSICS

What is Digital Forensics?

Digital Forensics is the process of identifying, preserving, extracting, analyzing, and presenting digital evidence in a legally acceptable manner to uncover the truth about a security incident or crime.

Goals of Digital Forensics

- ✓ Identify the source and nature of an incident
- ✓ Preserve digital evidence without altering it
- ✓ Reconstruct events and find the root cause
- ✓ Support legal actions and compliance

Digital Forensics Process (DFIR)



1. **Identification** — Identify potential evidence sources (devices, logs, cloud, network).
2. **Preservation** — Preserve data in its original state. Use write blockers, chain of custody.
3. **Collection** — Collect data using forensic tools (disk image, memory dump, logs).
4. **Examination** — Analyze data using techniques and tools to find artifacts.
5. **Analysis** — Interpret findings, build timeline, correlate events.
6. **Reporting** — Document findings clearly for legal and management use.

• Types of Digital Evidence

Evidence Type	Examples
Volatile Data	RAM contents, running processes, network connections, system logs (temporary).
Non-Volatile Data	Hard drives, SSDs, USBs, mobile devices, emails, docs.
Network Evidence	Packet captures, firewall logs, IDS/IPS logs, DNS logs.
Cloud Evidence	Cloud storage, logs, VM snapshots, SaaS activity logs.
Application Evidence	Chat logs, browser history, metadata, databases.
Physical Evidence	Printed documents, CCTV footage, badges, etc.

• Common Forensic Tools

Tool Category	Examples
Disk Forensics	EnCase, FTK Imager, Autopsy, X-Ways Forensics
Memory Forensics	Volatility, Rekall, WinPmem
Network Forensics	Wireshark, NetworkMiner, Zeek
Mobile Forensics	Cellebrite, Oxygen Forensics, MOBILedit
Log Analysis	Splunk, ELK Stack, Log2Timeline
Malware Analysis	IDA Pro, Ghidra, Cuckoo Sandbox, Any.run

• DFIR Best Practices

- ✓ Always follow legal procedures and permissions.
- ✓ Preserve evidence: do not alter original data.
- ✓ Maintain chain of custody.
- ✓ Use trusted and validated forensic tools.
- ✓ Document every step.
- ✓ Store evidence securely.
- ✓ Ensure report is clear, accurate and unbiased.

Chain of Custody

A documented process that tracks the seizure, custody, transfer, analysis and storage of digital evidence from start to end.

• Incident Response vs Digital Forensics

Aspect	Incident Response (IR)	Digital Forensics (DF)
Primary Goal	Minimize impact and restore operations	Find the truth and support legal actions
Focus	Contain, eradicate, recover	Preserve, collect, analyze evidence
Time Sensitivity	Immediate / Real-time	After incident / Post-event
Tools	SIEM, EDR, Firewalls, AV	Forensic Tools, Imagers, Analyzers
Output	Recovery and prevention	Reports and evidence for legal use
Team	IR Team / SOC Analysts	Forensic Analysts / Investigators

Key Takeaway: Incident Response helps you handle the present attack. | Digital Forensics helps you understand what happened.

Respond Quickly. Preserve Evidence. Learn and Improve.

15. Cybersecurity Tools + Quick Revision Notes

A. CYBERSECURITY TOOLS (CHEAT SHEET)

Tools every Cybersecurity learner should know!

Category	Tool	Purpose	Example Use
Information Gathering	Nmap	Network discovery, port scanning	nmap -sS 192.168.1.1
Network Analysis	Wireshark	Packet capture and analysis	Analyze suspicious traffic
Vulnerability Scanning	Nessus	Scan for vulnerabilities	Identify missing patches
Web Application Testing	Burp Suite	Intercept, test and modify web traffic	Find SQLi, XSS, CSRF, etc.
Exploitation Framework	Metasploit	Exploit vulnerabilities, payload delivery	Use modules to gain access
Password Attacks	Hydra	Brute force login credentials	hydra -l admin -P pass.txt 192.168.1.10
Web Proxy	OWASP ZAP	Find security issues in web apps	Active & Passive scanning
Enumeration	Enum4linux	Enumerate users, shares, systems	enum4linux -a 192.168.1.20
Wireless Testing	Aircrack-ng	Assess Wi-Fi security	Capture handshake & crack WPA/WPA2
Password Cracking	John the Ripper	Crack passwords (hash files)	john hash.txt
Log Analysis	Splunk / ELK	Analyze logs and detect threats	SIEM for monitoring and alerts
Malware Analysis	IDA Pro / Ghidra	Reverse engineer malware	Analyze malware behavior
Digital Forensics	Autopsy	Analyze disk images and artifacts	Recover deleted files, timeline
Cloud Security	AWS IAM Access Analyzer	Analyze IAM policies and permissions	Find overly permissive access
Container Security	Trivy	Scan containers for vulnerabilities	trivy image ubuntu:latest

B. QUICK REVISION NOTES (SUMMARY)

1. **Network Security Basics**
   Protects data in transit using firewalls, IDS/IPS, encryption and secure protocols.
2. **Authentication & Authorization**
   Authentication verifies identity. Authorization determines what resources a user can access.
3. **Firewalls, IDS & IPS**
   Firewall filters traffic, IDS monitors & alerts, IPS blocks malicious traffic in real-time.
4. **Web Application Security**
   Prevent OWASP Top 10 attacks: SQLi, XSS, CSRF, IDOR, Security Misconfigurations, etc.
5. **Access Control & Password Security**
   Use strong passwords, MFA and least privilege access to reduce risk.
6. **VPN & Security Protocols**
   VPN encrypts data over public networks. Use protocols like TLS, SSH, IPSec, HTTPS.
7. **Cloud & Mobile Security**
   Secure cloud with IAM, encryption, logging. Secure mobile with app hardening, MDM.
8. **Ethical Hacking & Penetration Testing**
   Follow methodology to find and exploit vulnerabilities (with permission).
9. **Incident Response & Digital Forensics**
   IR: Prepare, Detect, Contain, Eradicate, Recover, Lessons Learned.
   DF: Identify, Preserve, Collect, Analyze, Report.

Golden Rule
Think like an attacker, act like a defender, always follow ethics and the law.

C. IMPORTANT CONCEPTS – ONE LINERS

- **Confidentiality** – Ensure data is accessible only to authorized users.
- **Integrity** – Ensure data is accurate and not tampered.
- **Availability** – Ensure systems and data are available when needed.
- **CIA Triad** – Core principle of Cybersecurity.
- **Defense in Depth** – Use multiple layers of security.
- **Least Privilege** – Give minimum access required to perform a task.
- **Encrypt Everything** – Data at rest and in transit.
- **Always Patch** – Keep systems and applications updated.
- **Monitor & Log** – You can't protect what you don't monitor.
- **Backups Save Lives** – Regular backups ensure quick recovery.

D. SECURITY PRINCIPLES (REMEMBER)

C	I	A	N
Confidentiality	Integrity	Availability	Non-repudiation
Keep information secret.	Ensure information is accurate and complete.	Ensure information and services are available.	Ensure actions cannot be denied.

E. COMMON ATTACKS – QUICK LIST

- ✓ Phishing / Spear Phishing
- ✓ Malware (Virus, Worms, Trojans, Ransomware)
- ✓ Man-in-the-Middle (MITM)
- ✓ SQL Injection
- ✓ Cross Site Scripting (XSS)
- ✓ Denial of Service (DoS / DDoS)
- ✓ Brute Force / Password Attacks
- ✓ Session Hijacking
- ✓ DNS Spoofing / Cache Poisoning
- ✓ Insider Threats

F. PORTS TO REMEMBER

Port	Protocol	Service	Port	Protocol	Service
20	TCP	FTP (Data)	110	TCP	POP3
21	TCP	FTP (Control)	143	TCP	IMAP
22	TCP	SSH	443	TCP	HTTPS
23	TCP	Telnet	3306	TCP	MySQL
25	TCP	SMTP	3389	TCP	RDP
53	UDP/TCP	DNS	8080	TCP	HTTP-Alt
80	TCP	HTTP			

G. QUICK CHECKLIST – SECURITY BEST PRACTICES

- ☑ Use strong passwords and change them regularly.
- ☑ Enable Multi-Factor Authentication (MFA).
- ☑ Keep OS, applications and firmware up to date.
- ☑ Use firewalls and antivirus/EDR solutions.
- ☑ Encrypt sensitive data.
- ☑ Follow least privilege access principle.
- ☑ Monitor logs and enable alerts.
- ☑ Regularly backup important data.
- ☑ Conduct security awareness training.
- ☑ Test systems for vulnerabilities and fix them.

H. MEMORY TRICKS (MNEMONICS)

1) **CIA Triad:** "C I A" – Confidentiality, Integrity, Availability
2) **Incident Response Phases:** "P D C E R L"
   Prepare, Detect, Contain, Eradicate, Recover, Lessons Learned
3) **Forensics Process:** "I P C A R"
   Identify, Preserve, Collect, Analyze, Report
4) **Strong Password Formula:** "L + U + N + S + Sym"
   Length + Uppercase + Number + Special Character

FINAL TAKEAWAY: Learn → Practice → Apply → Secure
Stay Curious, Stay Ethical, Stay Secure!